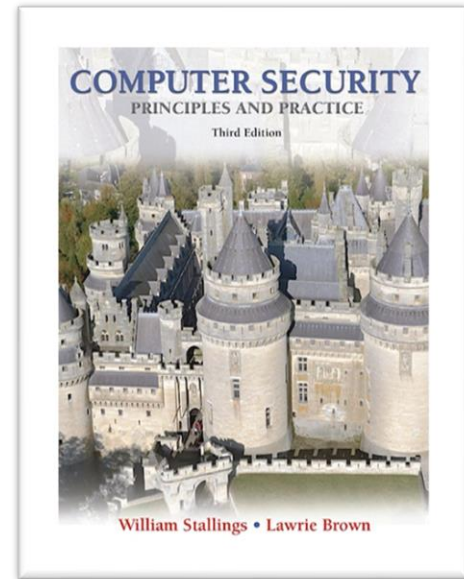


Lecture 10

Cloud Security

MODIFIED FROM SLIDES OF LAWRIE BROWN,
RAGIB HASAN, YOUNSUN CHO, ANYA KIM



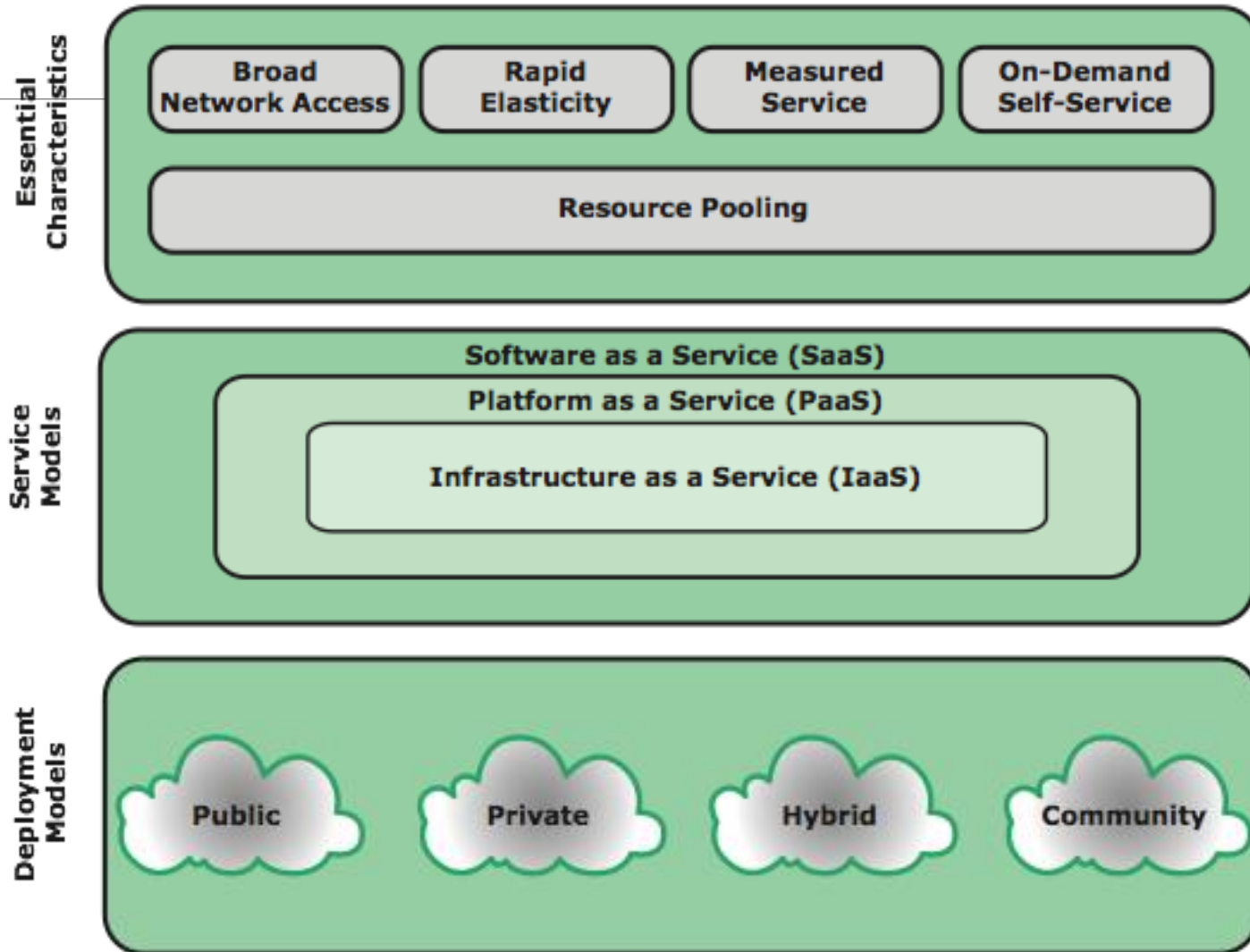


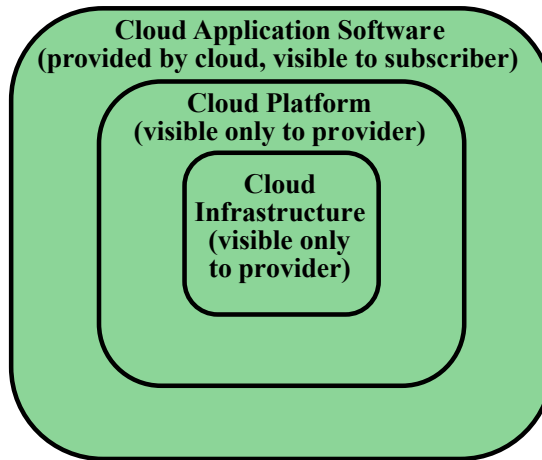
Cloud Computing

NIST defines cloud computing as follows:

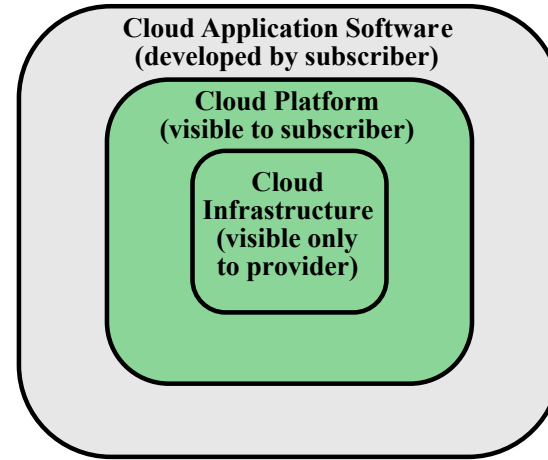
“A model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction.”

Cloud Computing Elements

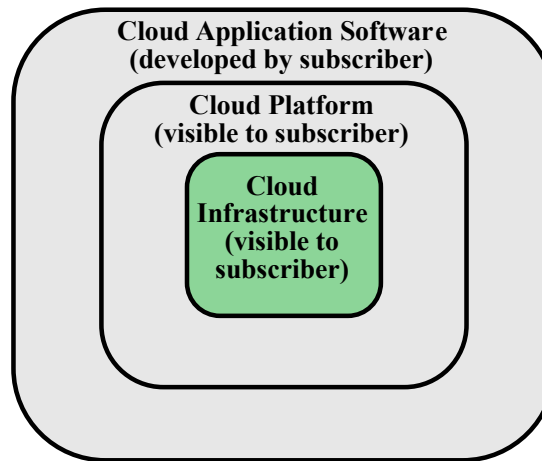




(a) SaaS



(b) PaaS



(c) IaaS

Figure 5.12 Cloud Service Models

NIST Deployment Models

Public cloud

- The cloud infrastructure is made available to the general public or a large industry group and is owned by an organization selling cloud services
- The cloud provider is responsible both for the cloud infrastructure and for the control of data and operations within the cloud

Private cloud

- The cloud infrastructure is operated solely for an organization
- It may be managed by the organization or a third party and may exist on premise or off premise
- The cloud provider is responsible only for the infrastructure and not for the control

Community cloud

- The cloud infrastructure is shared by several organizations and supports a specific community that has shared concerns
- It may be managed by the organizations or a third party and may exist on premise or off premise

Hybrid cloud

- The cloud infrastructure is a composition of two or more clouds that remain unique entities but are bound together by standardized or proprietary technology that enables data and application portability

Cloud Computing Context

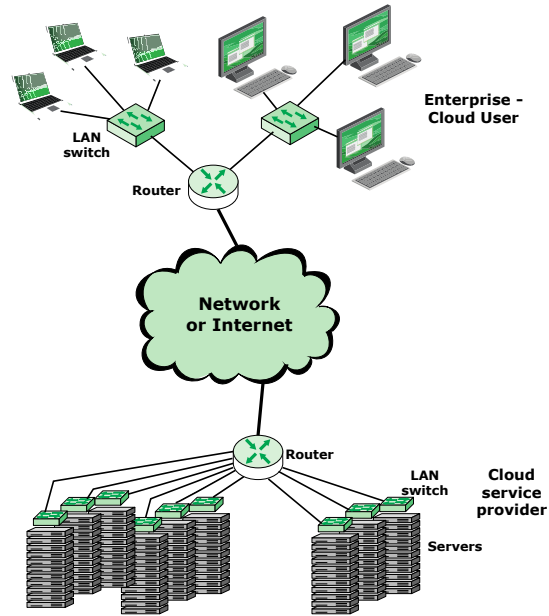
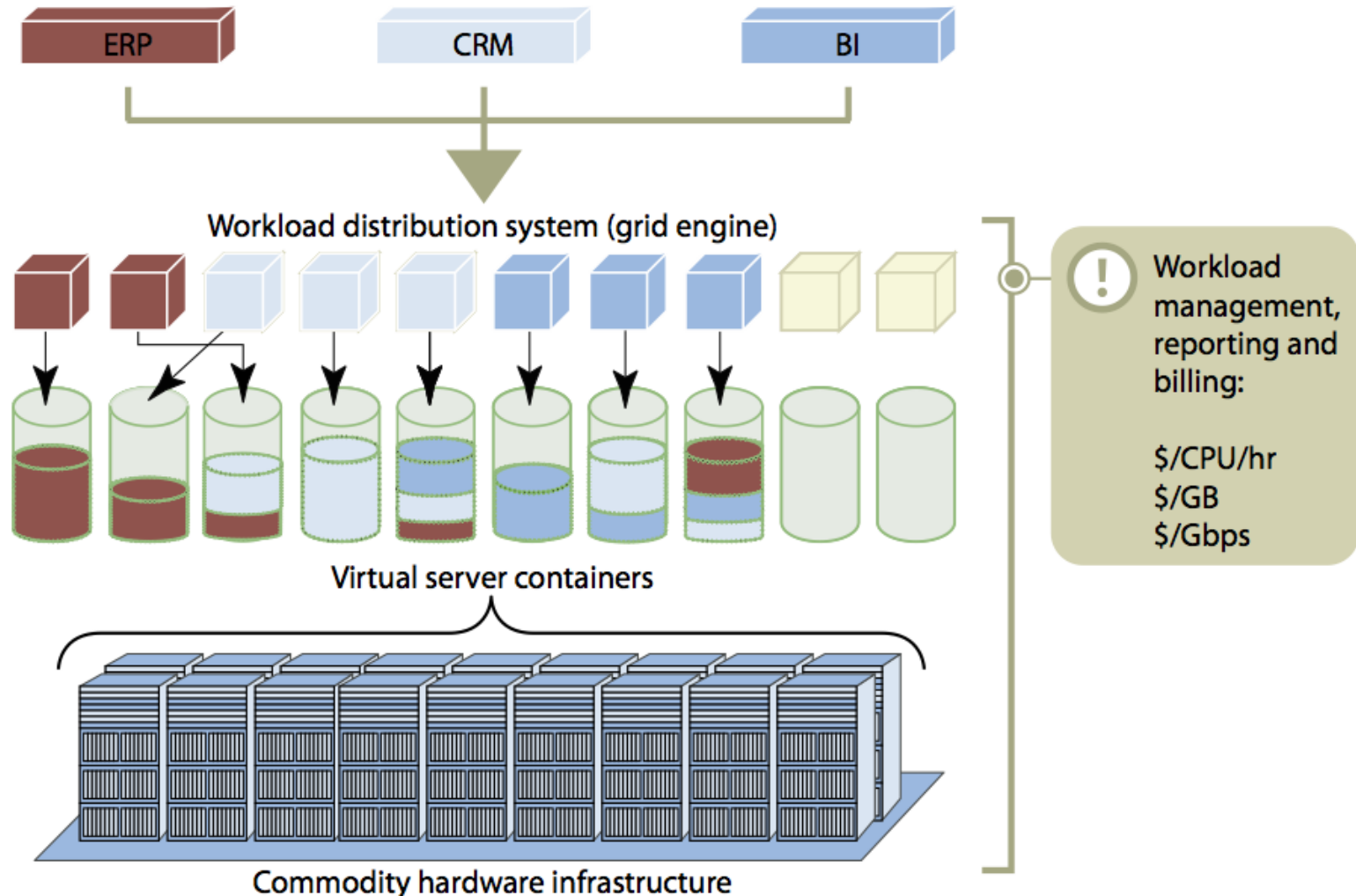


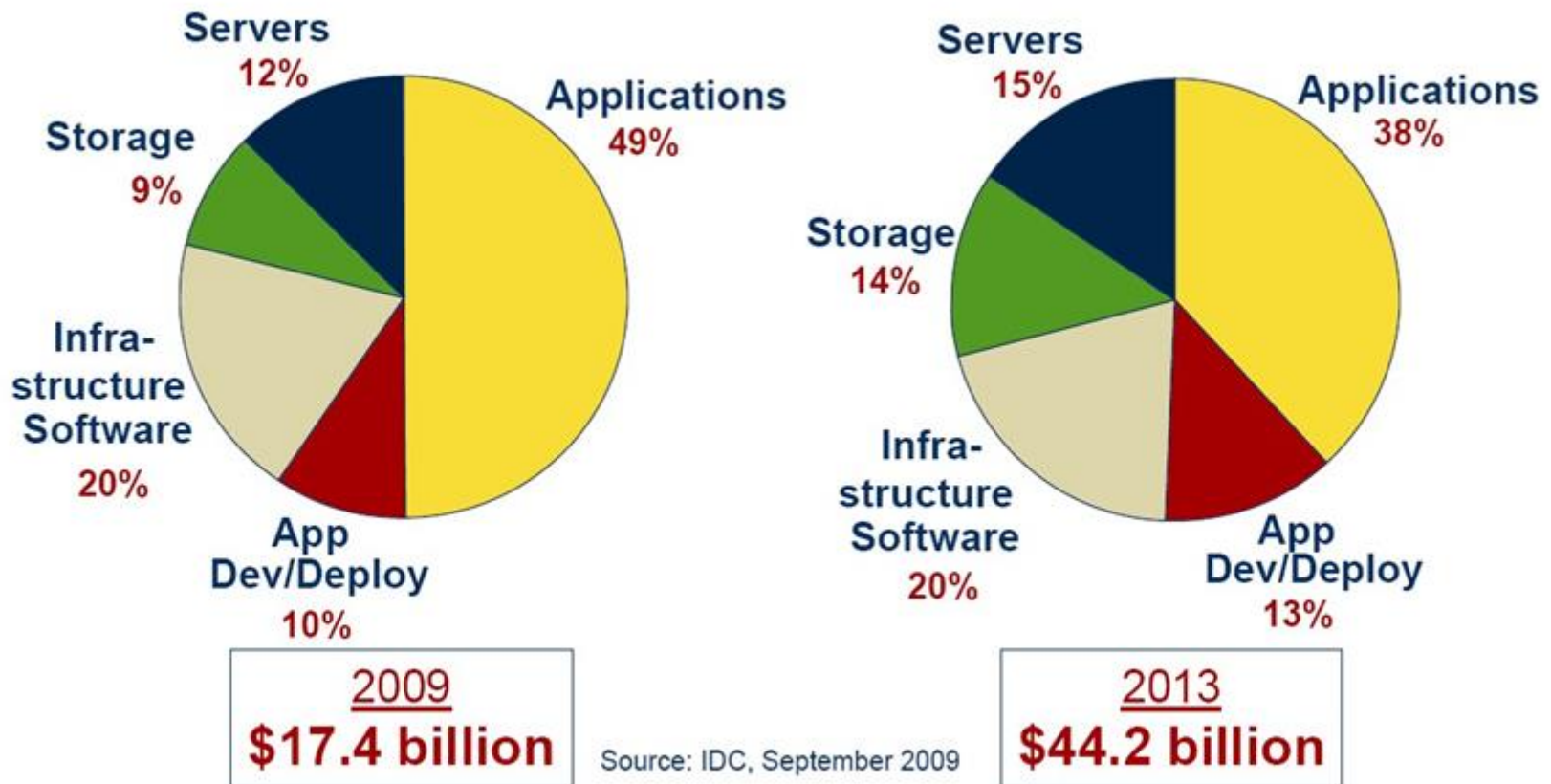
Figure 5.13 Cloud Computing Context

Cloud Fundamentals



Cloud Distribution Examined

Worldwide IT Cloud Services Revenue* by Product/Service Type



* Includes revenue from delivery of Applications, App Development/Deployment SW, Systems Infrastructure SW, and Server and Disk Storage capacity via Cloud Services model; AD&D excludes online B2B messaging providers/exchanges



Cloud Security Risks

The Cloud Security Alliance lists the following as the top cloud specific security threats:

- abuse use of cloud computing
- insecure interfaces and APIs
- malicious insiders
- shared technology issues
- data loss or leakage
- account or service hijacking
- unknown risk profile

Data Protection in the Cloud

the threat of data compromise increases in the cloud

risks and challenges that are unique to the cloud

architectural or operational characteristics of the cloud environment

multi-instance model

provides a unique DBMS running on a virtual machine instance for each cloud subscriber

gives the subscriber complete control over administrative tasks related to security

multi-tenant model

provides a predefined environment for the cloud subscriber that is shared with other tenants typically through tagging data with a subscriber identifier

gives the appearance of exclusive use of the instance but relies on the cloud provider to establish and maintain a secure database environment

Cloud Security As A Service

SecaaS

Is a segment of the SaaS offering of a CP

Defined by The Cloud Security Alliance as

- the provision of security applications and services via the cloud
 - either to cloud-based infrastructure and software or from the cloud to the customers' on-premise systems

Traditional systems security vs Cloud Computing Security



Securing a house

Owner and user are
often the same entity

Analogy



Securing a motel

Owner and users are almost
invariably distinct entities

Traditional systems security vs Cloud Computing Security



Securing a house

Biggest user concerns

- Securing perimeter
- Checking for intruders
- Securing assets



Securing a motel

Biggest user concern

- Securing room against
(the bad guy in next
room | hotel owner)

Who is the attacker?

Insider?

- Malicious employees at client
- Malicious employees at Cloud provider
- Cloud provider itself

Outsider?

- Intruders
- Network attackers?

Attacker Capability: Malicious Insiders

At client

- Learn passwords/authentication information
- Gain control of the VMs

At cloud provider

- Log client communication

Attacker Capability: Cloud Provider

What?

- Can read unencrypted data
- Can possibly peek into VMs, or make copies of VMs
- Can monitor network communication, application patterns

Attacker motivation: Cloud Provider

Why?

- Gain information about client data
- Gain information on client behavior
- Sell the information or use itself

Why not?

- Cheaper to be honest?

Why? (again)

- Third party clouds?

Attacker Capability: Outside attacker

What?

- Listen to network traffic (passive)
- Insert malicious traffic (active)
- Probe cloud structure (active)
- Launch DoS

Novel attacks on clouds

Question: Can you attack a cloud or other users, without violating any law?

Answer: Yes!! By launching side channel attacks, while not violating Acceptable User Policy.

- A Side Channel is a passive attack in which attacker gains information about target through indirect observations.

Why Cloud Computing brings new threats?

Traditional system security mostly means keeping bad guys out

The attacker needs to either compromise the auth/access control system, or impersonate existing users



Why Cloud Computing brings new threats?

But clouds allow co-tenancy :

Multiple independent users
physical infrastructure



share the same

So, an attacker can legitimately be in the same physical
machine as the target

Challenges for the attacker

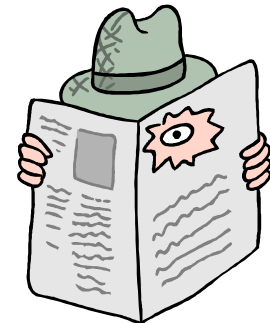
How to find out where the target is located



How to be co-located with the target in the same (physical) machine



How to gather information about the target



More on attacks...

1. Can one determine where in the cloud infrastructure an instance is located?
2. Can one easily determine if two instances are co-resident on the same physical machine?
3. Can an adversary launch instances that will be co-resident with other user instances?
4. Can an adversary exploit cross-VM information leakage once co-resident?

Answer: Yes to all

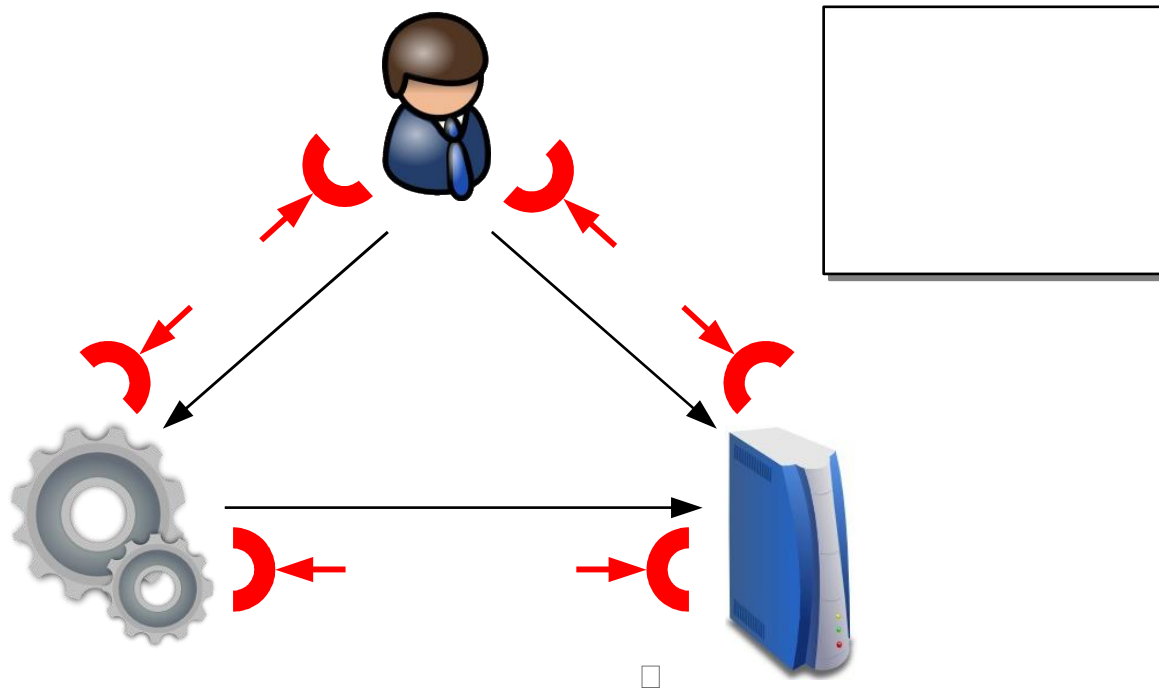
Clouds extend the attack surface

An **attack surface** is a vulnerability in a system that malicious users may utilize

How?

- By requiring users to communicate with the cloud over a public / insecure network
- By sharing the infrastructure among multiple users

Analyzing Attack Surfaces in Clouds



Cloud attack surfaces can be modeled using a 3 entity model (user, service, cloud)

Figure from: Gruschka et al., Attack Surfaces: A Taxonomy for Attacks on Cloud Services.

Attack Surface: 1

Service interface exposed towards clients

Possible attacks: Common attacks in client-server architectures

- E.g., Buffer overflow, SQL injection, privilege escalation

Attack Surface: 2

User exposed to the service

Common attacks

- E.g., SSL certificate spoofing, phishing

Attack Surface: 3

Cloud resources/interfaces exposed to service

Attacks run by service on cloud infrastructure

- E.g., Resource exhaustion, DoS

Attack Surface: 4

Service interface exposed to cloud

Privacy attack

Data integrity attack

Data confidentiality attack

Attack Surface: 5

Cloud interface exposed to users

Attacks on cloud control

Attack Surface: 6

User exposed to cloud

How much the cloud can learn about a user?

Problems Associated with Cloud Computing

Most security problems stem from:

- Loss of control
- Lack of trust (mechanisms)
- Multi-tenancy

These problems exist mainly in 3rd party management models

- Self-managed clouds still have security issues, but not related to above

Loss of Control in the Cloud

Consumer's loss of control

- Data, applications, resources are located with provider
- User identity management is handled by the cloud
- User access control rules, security policies and enforcement are managed by the cloud provider
- Consumer relies on provider to ensure
 - Data security and privacy
 - Resource availability
 - Monitoring and repairing of services/resources

Lack of Trust in the Cloud

Trusting a third party requires taking risks

Defining trust and risk

- Opposite sides of the same coin (J. Camp)
- People only trust when it pays (Economist's view)
- Need for trust arises only in risky situations

Defunct third party management schemes

- Hard to balance trust and risk
- e.g. Key Escrow (Clipper chip)
- Is the cloud headed toward the same path?

Multi-tenancy Issues in the Cloud

Conflict between tenants' opposing goals

- Tenants share a pool of resources and have opposing goals

How does multi-tenancy deal with conflict of interest?

- Can tenants get along together and 'play nicely' ?
- If they can't, can we isolate them?

How to provide separation between tenants?

Cloud Computing brings new threats

- Multiple independent users share the same physical infrastructure
- Thus an attacker can legitimately be in the same physical machine as the target

Cloud Security Issues

Confidentiality

- Fear of loss of control over data
 - Will the sensitive data stored on a cloud remain confidential?
 - Will cloud compromises leak confidential client data
- Will the cloud provider itself be honest and won't peek into the data?

Integrity

- How do I know that the cloud provider is doing the computations correctly?
- How do I ensure that the cloud provider really stored my data without tampering with it?

Cloud Security Issues (cont.)

Availability

- Will critical systems go down at the client, if the provider is attacked in a Denial of Service attack?
- What happens if cloud provider goes out of business?
- Would cloud scale well-enough?
- Often-voiced concern
 - Although cloud providers argue their downtime compares well with cloud user's own data centers

Cloud Security Issues (cont.)

Privacy issues raised via massive data mining

- Cloud now stores data from a lot of clients, and can run data mining algorithms to get large amounts of information on clients

Increased attack surface

- Entity outside the organization now stores and computes data, and so
- Attackers can now target the communication link between cloud provider and client
- Cloud provider employees can be phished

Cloud Security Issues (cont.)

Auditability and forensics (out of control of data)

- Difficult to audit data held outside organization in a cloud
- Forensics also made difficult since now clients don't maintain data locally

Legal dilemma and transitive trust issues

- Who is responsible for complying with regulations?
 - e.g., SOX, HIPAA, GLBA ?
- If cloud provider subcontracts to third party clouds, will the data still be secure?

Cloud Security Issues (cont.)

Security is one of the most difficult task to implement in cloud computing.

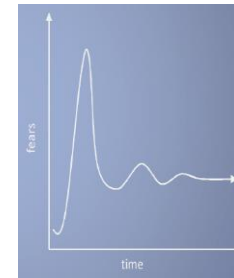
- Different forms of attacks in the application side and in the hardware components

Attacks with catastrophic effects only needs one security flaw



Cloud Computing is a **security nightmare** and it can't be handled in traditional ways.

John Chambers
CISCO CEO



Possible Solutions

Minimize Lack of Trust: Policy Language

Consumers have specific security needs but don't have a say-so in how they are handled

- Currently consumers cannot dictate their requirements to the provider (SLAs are one-sided)

Standard language to convey one's policies and expectations

- Agreed upon and upheld by both parties
- Standard language for representing SLAs

Create policy language with the following characteristics:

- Machine-understandable (or at least processable),
- Easy to combine/merge and compare

Minimize Lack of Trust: Certification

Certification

- Some form of reputable, independent, comparable assessment and description of security features and assurance
 - Sarbanes-Oxley, DIACAP, DISTCAP, etc

Risk assessment

- Performed by certified third parties
- Provides consumers with additional assurance

Minimize Loss of Control: Monitoring

Cloud consumer needs situational awareness for critical applications

- When underlying components fail, what is the effect of the failure to the mission logic
- What recovery measures can be taken
 - by provider and consumer

Requires an application-specific run-time monitoring and management tool for the consumer

- The cloud consumer and cloud provider have different views of the system
- Enable both the provider and tenants to monitor the components in the cloud that are under their control

Minimize Loss of Control: Monitoring

Provide mechanisms that enable the provider to act on attacks he can handle.

- infrastructure remapping
 - create new or move existing fault domains
- shutting down offending components or targets
 - and assisting tenants with porting if necessary
- Repairs

Provide mechanisms that enable the consumer to act on attacks that he can handle

- application-level monitoring
- RAdAC (Risk-adaptable Access Control)
- VM porting with remote attestation of target physical host
- Provide ability to move the user's application to another cloud

Minimize Loss of Control: Utilize Different Clouds

The concept of ‘Don’t put all your eggs in one basket’

- Consumer may use services from different clouds through an intra-cloud or multi-cloud architecture
- A multi-cloud or intra-cloud architecture in which consumers
 - Spread the risk
 - Increase redundancy (per-task or per-application)
 - Increase chance of mission completion for critical applications
- Possible issues to consider:
 - Policy incompatibility (combined, what is the overarching policy?)
 - Data dependency between clouds
 - Differing data semantics across clouds
 - monitoring technology
 - Is it worth it to spread your sensitive data across multiple clouds?
 - Redundancy could increase risk of exposure

Minimize Loss of Control: Access Control

Many possible layers of access control

- E.g. access to the cloud, access to servers, access to services, access to databases (direct and queries via web services), access to VMs, and access to objects within a VM
- Depending on the deployment model used, some of these will be controlled by the provider and others by the consumer

Regardless of deployment model, provider needs to manage the user authentication and access control procedures (to the cloud)

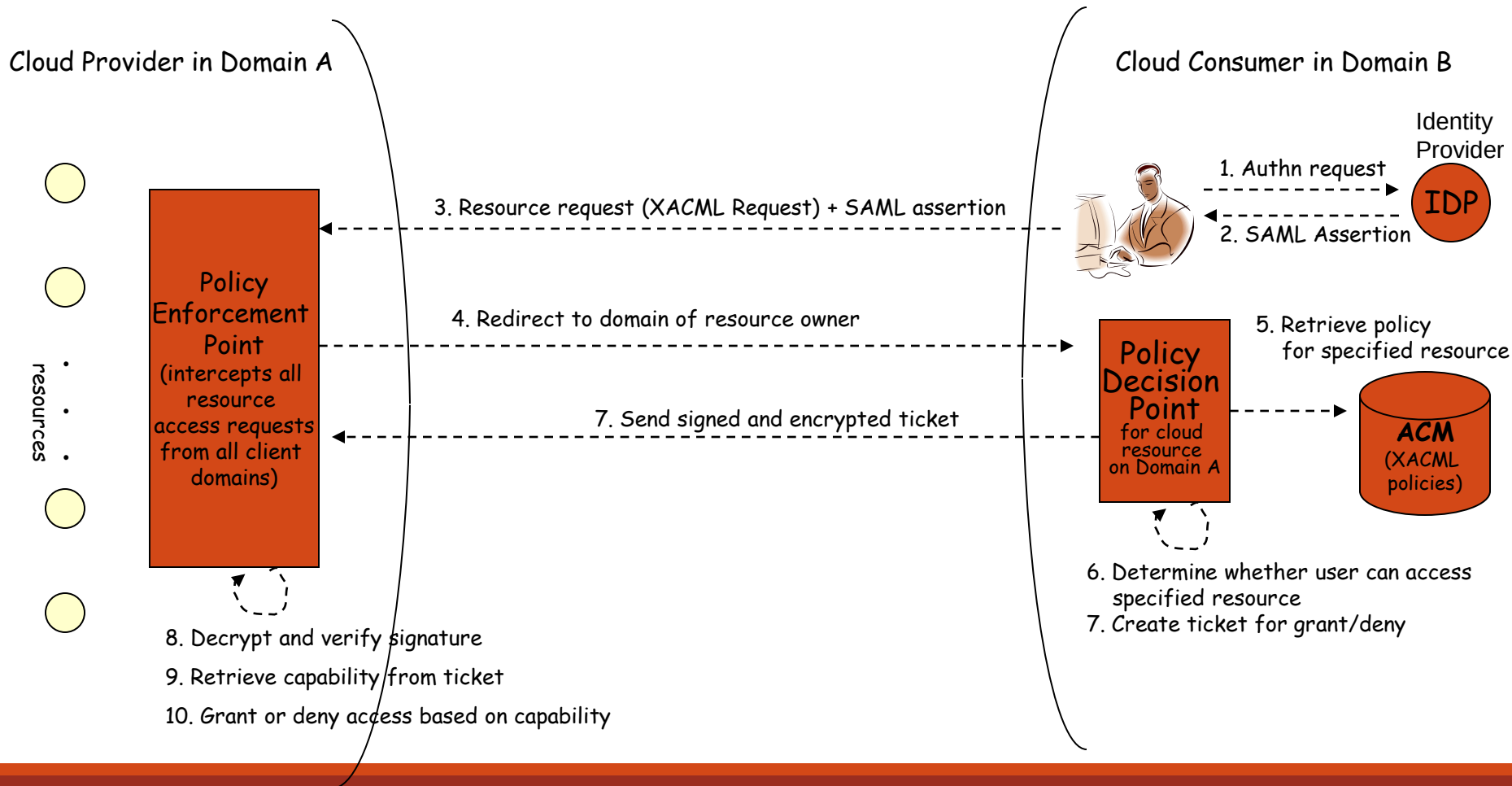
- Federated Identity Management: access control management burden still lies with the provider
- Requires user to place a large amount of trust on the provider in terms of security, management, and maintenance of access control policies.

Minimize Loss of Control: Access Control

Consumer-managed access control

- Consumer retains decision-making process to retain some control, requiring less trust of the provider
- Requires the client and provider to have a pre-existing trust relationship, as well as a pre-negotiated standard way of describing resources, users, and access decisions between the cloud provider and consumer.
 - It also needs to be able to guarantee that the provider will uphold the consumer-side's access decisions.
- Should be at least as secure as the traditional access control model.

Minimize Loss of Control: Access Control



Minimize Multi-tenancy

Can't really force the provider to accept less tenants

- Can try to increase isolation between tenants
 - Strong isolation techniques (VPC to some degree)
 - QoS requirements need to be met
 - Policy specification
- Can try to increase trust in the tenants
 - Who's the insider, where's the security boundary? Who can I trust?
 - Use SLAs to enforce trusted behavior

Conclusion

Cloud computing is sometimes viewed as a reincarnation of the classic mainframe client-server model

- However, resources are ubiquitous, scalable, highly virtualized
- Contains all the traditional threats, as well as new ones

In developing solutions to cloud computing security issues it may be helpful to identify the problems and approaches in terms of

- Loss of control
- Lack of trust
- Multi-tenancy problems